

Nom : WIDAMOU YANDA

NIVEAU : MASTER 2

FILIERE : SISD

EXERCICE V : CHAPITRE 5

Ex. 5.1 Stratégie d'acquisition

Face à un serveur allumé avec une session RDP suspecte, l'ordre des actions est dicté par le principe de la RFC 3227 (ordre de volatilité) et la nécessité de ne pas alerter l'attaquant.

1. **Isoler le serveur au niveau réseau (mais ne pas débrancher) :** Déconnecter le câble réseau ou isoler le port sur le switch. *Justification : Empêcher l'attaquant de supprimer des preuves ou de propager l'attaque, tout en gardant le serveur allumé pour la RAM.*
2. **Photographier l'écran :** Capturer l'état visuel (session RDP ouverte, outils affichés). *Justification : Documenter l'état initial de la scène de crime numérique.*
3. **Collecter la mémoire vive (RAM) :** Utiliser un outil comme DumpIt ou Magnet RAM Capture sur une clé USB dédiée. *Justification : La RAM est l'élément le plus volatile ; elle contient les connexions RDP, les processus de l'attaquant et d'éventuels mots de passe en clair.*
4. **Lister les connexions réseau actives (netstat) :** Exécuter `netstat -ano`. *Justification : Identifier l'adresse IP source de l'attaquant et le processus associé à la session RDP.*
5. **Capturer l'état des processus (tasklist) :** *Justification : Identifier les exécutable suspects lancés par la session RDP avant qu'ils ne soient fermés.*
6. **Extraire les logs volatils (journaux d'événements récents) :** *Justification : Les logs en mémoire peuvent être perdus si le système redémarre brusquement.*
7. **Éteindre proprement ou forcer l'arrêt (selon la politique) :** Généralement, un retrait de prise est préféré pour figer l'état du disque si le chiffrement est craint. *Justification : Préparer le disque pour une acquisition statique.*
8. **Mettre sous scellé physique :** Apposer des étiquettes d'inviolabilité sur les ports et le boîtier. *Justification : Garantir la chaîne de possession (Custody).*

Ex. 5.2 Commande d'acquisition

La commande `dcfldd` est privilégiée en forensique car elle calcule le hash pendant la copie.

Commande d'acquisition :

`sha256sum /mnt/evidence/erp-sdc.dd`

Ex. 5.3 PV de saisie

PROCÈS-VERBAL DE SAISIE ET DE COLLECTE NUMÉRIQUE

Dossier : Incident LiZbiZ-SIS / srv-erp-01

Date/Heure : 07 Mai 2026 à 14h30

Lieu : Salle Serveurs, Siège Social

1. DESCRIPTION DE L'ÉLÉMENT

- **Type de matériel :** Disque dur interne (extrait de srv-erp-01)
- **Marque/Modèle :** Seagate IronWolf 2To
- **Numéro de Série (S/N) :** ZA123456
- **État :** Bon état apparent, extrait après isolation réseau.

2. PROCÉDÉ D'ACQUISITION

- **Outil utilisé :** dcfldd (version 1.7) via station forensique Linux.
- **Support de destination :** Disque externe de preuve /mnt/evidence (ID: EVIDENCE-01).
- **Empreinte Numérique (Hash SHA-256) :**
8f434346648f6b96df89dda901c5176b10a6d83961dd3c1ac88b59b2ec3e307d
- **Bloqueur d'écriture :** Utilisation d'un pont USB Tableau T35u (Hardware Write-Blocker).

3. CHAÎNE DE POSSESSION

- **Saisi par :** WIDAMOU
- **Transmis à :** Responsable Sécurité / Coffre-fort preuves.
- **Date de transfert :** 07/05/2026 à 16h00.
- **Raison :** Stockage sécurisé pour analyse ultérieure.

Signature de l'Expert : _____

Signature du Témoin/Responsable : _____

EXERCICE VI : CHAPITRE 6

Ex. 6.1 Analyse du registre

L'analyse des fichiers "hives" du registre Windows permet de reconstituer la configuration et les traces d'exécution.

- **(a) Clés Run (Persistance logicielle) :**

- **Clé :**
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Run
- **Trouvaille :** Présence d'une entrée suspecte nommée SystemUpdate pointant vers C:\Users\Public\svchost.exe.
- **(b) Comptes locaux (Base SAM) :**
 - **Clé :**
HKEY_LOCAL_MACHINE\SAM\SAM\Domains\Account\Users\Names
 - **Trouvaille :** Outre les comptes standards, identification du compte **backup** créé ou activé juste avant l'incident.
- **(c) Fuseau horaire (Timezone) :**
 - **Clé :**
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\TimeZoneInformation
 - **Trouvaille :** TimeZoneKeyName configuré sur W. Central Africa Standard Time (UTC+1), correspondant au fuseau horaire du Cameroun.

Ex. 6.2 Timeline NTFS

La timeline permet de corréler les modifications de fichiers avec les logs réseau.

Procédure de génération :

1. fls -r -m C: srv-web-01.dd > bodyfile
2. mactime -b bodyfile -d -z UTC 2026-04-12..2026-04-12 > timeline.csv

Analyse des 5 événements suspects (02:00 – 06:00 UTC) :

HEURE	Evénement	Action	Mitre
03:15:22	/windows/Temp/nc.exe	.A..	T1105 arrivé netcat
03:20:10	/var/www/html/shell.php	. M..	T1505.003 injection du shell
03:45:12	/windows/system32/config/SAM	..C.	T1003 tentative d'extraction
03:48:00	/windows/system32/winevt/logs/security.evtx	.M..	T1070.001 effacement des logs
04:10:05	/users/Admin/desktop/donnees_client.zip	B...	T1560 preparation a l'exfiltration

Ex. 6.3 Détection de persistance Linux

Sur une image Linux, la persistance se cache souvent dans les fichiers de configuration ou les scripts de démarrage.

1. Cron Jobs (Planification) :

- Vérification de `/etc/crontab` et `/var/spool/cron/crontabs/`.
- *Trouvaille* : Une ligne exécutant un script caché `/dev/shm/.kworker` toutes les heures.

2. Systemd Services :

- Analyse des fichiers dans `/etc/systemd/system/`.
- *Trouvaille* : Service `backdoor.service` configuré pour se relancer automatiquement (`Restart=always`).

3. Détournement de bibliothèques (LD_PRELOAD) :

- Vérification du fichier `/etc/ld.so.preload`.
- *Risque* : Permet d'intercepter les appels système et de cacher des fichiers/processus (Rootkit).

4. Accès SSH (authorized_keys) :

- Inspection de `/home/user/.ssh/authorized_keys`.
- *Trouvaille* : Ajout d'une clé publique étrangère permettant un accès permanent sans mot de passe (T1098.004).

5. Scripts de profil (bashrc) :

- Analyse de `~/.bashrc` ou `/etc/profile`.
- *Trouvaille* : Un alias ou une commande `alias sudo='...'` pour capturer le mot de passe administrateur lors de sa saisie.